

ECCS 4441 Ethical Hacking & Pen Testing

Module 1

Introduction to Penetration Testing



What, Why, When, How, and Who? (1 of 6)

What Is Penetration Testing?

- Commonly called “pen testing” or “ethical hacking”
- Authorized security tests on targets to discover vulnerabilities
 - Targets include computing devices, applications, physical resources and personnel
 - Vulnerabilities include flaws in software, hardware, operational procedure
- *Exploit* – software, data, or commands taking advantage of vulnerabilities to cause unintended behavior in target system

Review Question

- What are two other terms for penetration testing?
 - a) Vulnerability testing
 - b) Pen testing
 - c) Ethical hacking
 - d) Blue teaming

What, Why, When, How, and Who? (3 of 6)

Why Do Security Professionals Pen Test?

- To discover vulnerabilities in targets before a threat actor does
 - Vulnerabilities can then be eliminated or mitigated
 - Finding and eliminating vulnerabilities improves overall security

Review Question

- The purpose of pen testing is to discover vulnerabilities in targets so that these vulnerabilities can be eliminated or mitigated.
 - a) True
 - b) False

What, Why, When, How, and Who? (4 of 6)

When Do Security Professionals Conduct Pen Tests?

- When a major change in the computing environment occurs
- According to the schedule for compliance requirements
 - Payment Card Industry Data Security Standard (PCI DSS)
 - PCI DSS v 4.0 Requirement 11
 - “Test security systems and processes regularly”
- At other strategic times and as necessary, determined by the organization

Review Question

- Pen testing should be performed under which of the following circumstances? Choose all that apply.
 - a) A new computer system has been installed.
 - b) A new software system or an update to a software system has been installed.
 - c) Following a regular schedule to make sure no unknown changes have impacted security.
 - d) Performed as dictated by compliance standards such as PCI DSS.

What, Why, When, How, and Who? (5 of 6)

How Do Security Professionals Pen Test?

- Several established penetration testing methodologies are used
- Pen test methodologies provide standardized guidance and process to conduct a pen test
- The type of target tested or the compliance requirement can drive methodology choice

What, Why, When, How, and Who? (6 of 6)

Who Performs Pen Tests?

- An authorized attacker performs pen tests
 - Known trusted entity
 - Member of organization IT Department
 - Outside third party hired to perform test

Review Question

- Which of the following are possible targets for penetration testing?
 - a) Web application.
 - b) Computer.
 - c) Staff.
 - d) All of these are correct.

CIA, DAD, and the Hacker Mindset (1)

CIA Triad – Confidentiality, Integrity, Availability

- One of the most well-known concepts and models in cybersecurity
- The three CIA concepts link together to provide security
 - Confidentiality: achieved using technology such as authentication, access control, and encryption
 - Integrity: achieved using authentication, access control, and digital signatures
 - Availability: objects and services are accessible when required by those authorized



CIA, DAD, and the Hacker Mindset (2)

DAD Triad – Disclosure, Alteration, Destruction

- Antithesis or opposite of the CIA triad
- Hacker's ultimate goal
 - Disclosure of confidential information
 - Alteration or corruption of integrity of information
 - Destruction or denial of availability of access to resources



CIA, DAD, and the Hacker Mindset

Ethical Hacking Guidelines – For Penetration Testers

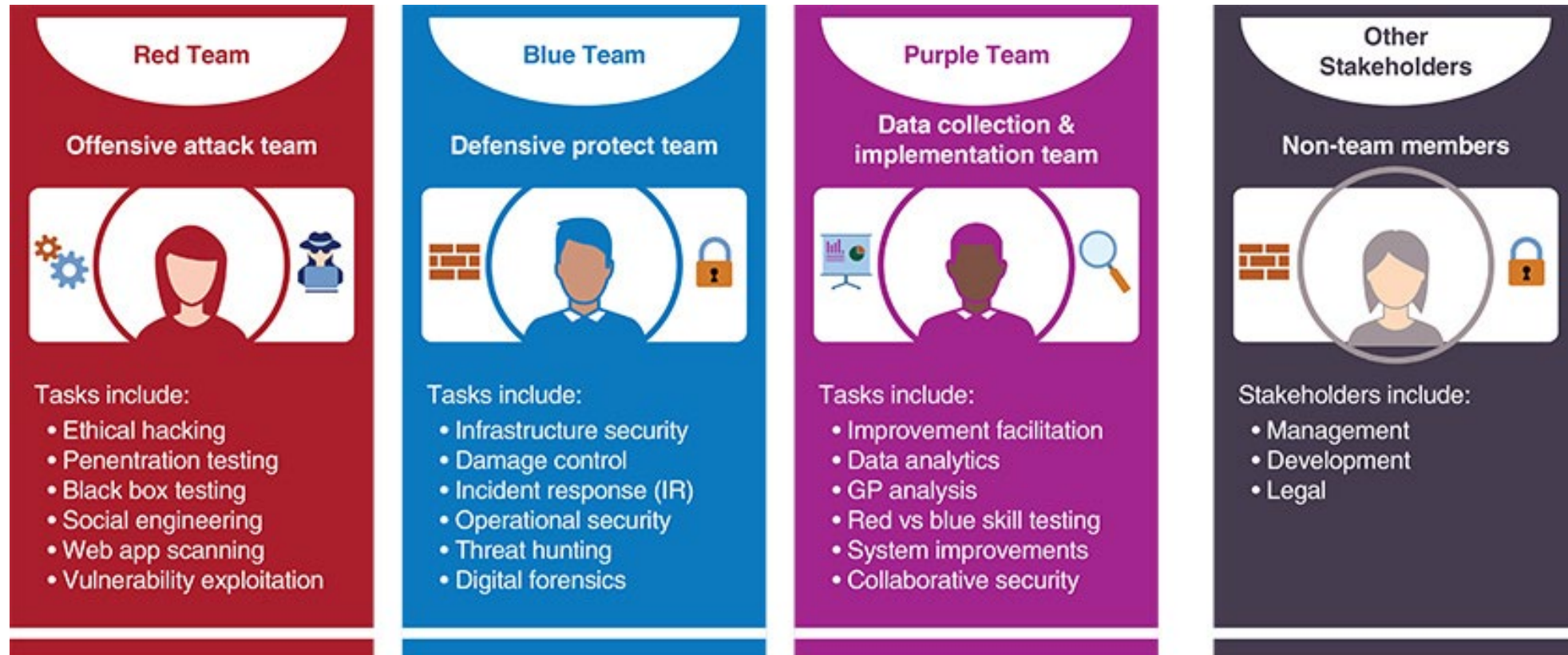
- Background checks for pen testers; no unethical behavior
- Pen testers must:
 - adhere to the specific scope of engagement
 - report evidence of criminal activity or breaches immediately
 - choose and limit tools and use wisely
 - limit invasiveness to meet the scope of engagement
- Confidentiality must always be maintained

The Pen-Test Teams and Other Stakeholders (1 of 5)

Key Participants in Penetration Tests

- Red Team – performs the security and pen testing
- Blue Team – attempts to detect or prevent red team activities
- Purple Team – data collection, analytics, facilitation of teams
- Other Stakeholders
 - IT Department
 - Management
 - Legal Department

The Pen-Test Teams and Other Stakeholders (2 of 5)



Pen-test teams

The Pen-Test Teams and Other Stakeholders (3 of 5)

Red Team

- Consists of pen-test team members
- May contain target organization team members such as IT Department
- Often has members with their own specialized skill sets
 - Team leaders and project managers
 - Programmers and scripters
 - Social engineers
 - Network and wireless engineers
 - Server and operating system administrators

The Pen-Test Teams and Other Stakeholders (4 of 5)

Blue Team

- Blue team may not always exist in pen-test engagements
- May consist of IT team members or contracted security services
- Blue team is responsible for:
 - Preparation
 - Detection
 - Identification
 - Containment
 - Recovery
 - Lessons learned
 - Implementation

The Pen-Test Teams and Other Stakeholders (5 of 5)

Purple Team

- Observes red and blue teams and guides them to a more effective test
- Understands the “big picture” and provides oversight
 - Gathers results
 - Performs analysis
 - Reports results

The Pen-Test Teams and Other Stakeholders

Other Stakeholders

- Management
 - Provides authorization and permission for pen test
- Development
 - Guides and oversees tests on custom software and applications
 - May provide attack guidance to red team
- Legal
 - Creates necessary documents to assure safe pen test
 - Create legal documents such as nondisclosure agreements

Review Question

- Which of the following are needed to properly maintain the ethical hacking mindset?
 - a) Pen testers must be careful to conduct themselves ethically with professionalism and integrity.
 - b) Pen testers must not accidentally stray into the realm of the malicious hacker and cause damage to systems or data.
 - c) Pen testers must do no harm and stay within the boundaries of what activities have been specified and sanctioned in the penetration testing agreement documents.
 - d) All of these are correct.

Review Question

- Which penetration testing team is responsible for launching “authorized attacks” against an organization’s resources/targets?
 - a) Red team
 - b) Blue team
 - c) Purple team
 - d) Other stakeholders

Review Question

- Which penetration testing team consists of defenders trying to detect and thwart attacks?
 - a) Red team
 - b) Blue team
 - c) Purple team
 - d) Other stakeholders

Review Question

- Which penetration testing team helps coordinate the pen- testing activities by providing an oversight role to bridge between other teams?
 - a) Red team
 - b) Blue team
 - c) Purple team
 - d) Other stakeholders

Review Question

- Which of the following groups are considered to be other stakeholders?
Choose all that apply.
 - a) Management
 - b) Development
 - c) Legal
 - d) IT Department

The Pen-Test Process (1 of 6)

Pen-Test Process



Pen-Test Process

The Pen-Test Process (2 of 6)

Planning and Scoping

- First step in a penetration test
- Specifies which computers, applications, and network device are targeted
- Identifies logistics, teams, stakeholders, and expectations
- Defines Rules Of Engagement (ROE)

The Pen-Test Process (3 of 6)

Planning and Scoping – Rules of Engagement

- How is sensitive information handled?
- How will project updates be communicated?
- Who are the emergency contacts?
- Which targets are in the scope?
- Are target personnel aware of the test activities?
- What should be done if previous compromises are discovered?

What are your thoughts on the Rules of Engagement in this Lab?

The Pen-Test Process (4 of 6)

Information Gathering and Vulnerability Scanning

- Red team goal is finding useful information about the target
- Initial goal is broad discovery and narrowing the focus as the test continues
- Other goals include:
 - Active reconnaissance
 - Vulnerability scanning and analysis
 - Social engineering

The Pen-Test Process (5 of 6)

Attacking and Exploiting

- Details are gathered in previous phase drive attacks
- Target configuration and status determine which attacks are used
 - Password cracking
 - SQL injection
 - Circumventing security settings
 - Physical attacks
 - Many other attacks, dependent on information gathered on targets

The Pen-Test Process (6 of 6)

Reporting and Communicating Results

- Information gathered up to this point is organized
- Report is created with specific problems found and actionable items identified
 - Vulnerabilities are uncovered
 - Successful attacks are identified
 - Fixes or remediation steps for vulnerabilities are outlined
- During this phase, a “clean up” of pen test occurs
- Proper reporting and communication

Review Question

- Which phase of the pen-testing process includes activities such as active reconnaissance, vulnerability scanning, and social engineering?
 - a) Planning and scoping
 - b) Information gathering and vulnerability scanning
 - c) Attacking and exploiting
 - d) Reporting and communicating results

Review Question

- Which phase of the pen-testing process includes activities such as getting written authorization, determining targets, defining goals, and building teams?
 - a) Planning and scoping
 - b) Information gathering and vulnerability scanning
 - c) Attacking and exploiting
 - d) Reporting and communicating results